
INTERNAL — CONFIDENTIAL

AthlasX

Audit & Test Report

Round 2 — post-remediation audit
plus a complete test suite

Version 2.0

Date August 2026

Audited main @ 30ca63c

The application now builds, type-checks clean and runs against a live database — 13 of 15 round-1 findings are fixed. One class of problem dominates what remains: there is no authentication anywhere, verified by executing the routes. The project had zero tests; it now has 118, of which 101 pass and 17 fail deliberately as an executable specification of the open findings.

Round 2 — post-remediation audit, plus a complete test suite

Version 2.0 · August 2026 · Internal — Confidential

Re-audit of the pivot implementation after Hritvik's four remediation commits, followed by construction of the project's first automated test suite: unit, integration, security and end-to-end.

Audited at `main` @ `30ca63c`, merging `d5af69b`, `be1b4d8`, `69bb40a`, `d03c9aa`.

Contents

1. Headline
 2. Build and runtime status
 3. Round-1 findings — what was fixed
 4. Open and new findings
 5. Environment status
 6. The test suite
 7. Results
 8. Coverage and what is not covered
 9. Remediation plan
 10. How to run everything
-

1. Headline

The application now builds, type-checks clean, and runs against a real database. That is a genuine turnaround from round 1, where it did not compile at all. Thirteen of the fifteen round-1 findings are properly fixed, and several were fixed well rather than papered over — the score engine's TQI handling now carries a comment reasoning explicitly about the numerator/denominator cancellation that was reported.

One class of problem dominates what remains: there is no authentication anywhere. All 24 API routes serve any caller, identity is taken from the request body, and the claim endpoint returns the OTP it just issued. This is verified by executing the routes, not inferred from reading them.

The project had **zero tests**. It now has **118**, of which 101 pass and 17 fail deliberately as an executable specification of the open findings.

	Round 1	Round 2
next build	fails — no root layout	passes
tsc --noEmit	32 errors	0 errors
Data layer	none	Prisma, 23 models, live Neon
Score engine	dead code	wired into 5 call sites
Automated tests	0	118
Authentication	none	still none

2. Build and runtime status

```
$ npx prisma generate && npx next build
✓ Compiled successfully
✓ Generating static pages (15/15)
  22 API routes, 15 pages
exit 0

$ npx tsc --noEmit
0 errors
```

Runtime was verified against a production server, not just a build:

```
GET /dashboard      → 200
GET /api/associations → 200 {"associations":[{"name":"UPCA", ...}]}
```

One caveat that will bite CI. The build only succeeds after `prisma generate`. Before it, all 34 type errors were the ungenerated client (`Property 'full_name' does not exist on type '{}'`). There was no `postinstall` hook, so a fresh clone or a CI runner would have reproduced the round-1 failure exactly. **A** `postinstall: prisma generate` script has been added as part of this work.

3. Round-1 findings — what was fixed

Finding	Status	Evidence
B1 no root layout	Fixed	src/app/layout.tsx added; build passes
B2 path alias pointed at repo root	Fixed	"@/*": ["../src/*"]
B3 recharts undeclared	Fixed	added to dependencies
B4 four modules never committed	Fixed	lib/utils, 3 UI primitives, AnimatedCounter pushed
B5 three sidebar links 404	Fixed	/notifications, /profile, /settings added
5.1 unassessed players capped at 75/100	Fixed well	renormalises against activeMax — only components actually present
5.2 batting average ignored not-outs	Fixed	now runs per dismissal, with a matches fallback
5.3 zero economy scored as no-data	Fixed	guard is now matches === 0 overs === 0
5.4 TQI cancelled out of strike rate	Fixed well	applied once as a qualityFactor on finished rate stats
6.1 score engine was dead code	Fixed	imported by the grading page and 4 API routes
6.2 duplicate type systems	Fixed	engine re-exports the canonical types
6.3 no data layer	Fixed	Prisma + 23 models + 24 routes against Neon
6.5 tsconfig pulled in the archive	Fixed	exclude: ["Old_SportX_Files_Initial"]
W2 claim flow	Built	search → start → verify → withdraw, with OTP hygiene
W8 academy matching	Partial	table, queue and confirm/reject exist; see §4

The schema design deserves specific credit. Both §7 structural requirements from the Pivot Document are met: `PlayerProfile.user_id` is nullable for shadow profiles, and `Performance` carries `source`, `ingest_method`, `confidence_score` and `association_approval_status`. The database is provisioned into its own `athlasx` Postgres schema, leaving the 41 legacy `public` tables untouched exactly as the schema comment promises.

4. Open and new findings

4.1 No authentication on any route — Critical

All 24 API routes are open. Verified by executing them against a running server with no credentials:

```
/api/dashboard      200    /api/trial-cycles   200
/api/candidate-pool  200    /api/ingest         200
/api/my-record       200    /api/academy-matching 200
```

`/api/candidate-pool` returned the names, ages, districts and scores of **17-year-olds** to an anonymous caller.

4.2 Identity is taken from the request body — Critical

`selectorId`, `chairId` and `playerId` all arrive in the POST body. The consequence is that the newly-added server-side blind grading is enforced against *accident*, not an *adversary*:

- `POST /api/grading/{id}/grade {"selectorId": "<chair uuid>"}` records a grade as the chair.
- `POST /api/grading/{id}/unlock {"chairId": "<chair uuid>"}` unlocks convergence for anyone who knows the UUID, exposing every selector's grade.

The enforcement logic itself is correct and well written — 15 integration tests confirm the boundary holds. It is the identity underneath it that is unverified.

4.3 `claim/start` returns the OTP — Critical

The response body includes `dev0tp`, honestly commented as a stopgap until an SMS gateway is wired. Combined with 4.1 this is a complete profile-takeover primitive against any player, including minors. The security suite captures real leaked codes (`143175`, `651226`) in its failure output.

4.4 Consent withdrawal does not stop processing — High, legal

`claim/withdraw` flips `consent_status` and its comment defers enforcement to "callers that read `consent_status`". **None of the five read paths do** — `candidate-pool`, `tracking`, `coach/squad`, `dashboard`, `my-record`. Under DPDP, withdrawal must stop processing, not merely record an intention.

4.5 Coach-rating provenance still absent — Open from round 1

`Pivot_Changes_ATHLASX.docx` states that ratings are "accepted only when source = 'coach' or 'supervisor'" and that "self-reported values are rejected at the engine level". There is still no `source` field on `AthlasXScoreInput` and no validation. This remains the highest-risk inaccuracy in the completion document, because verified-data-only is the trust guarantee sold to associations.

4.6 Bowling formula still disagrees with its own comment — Open from round 1

```
const ecoScore = clamp(((10 - economy) / 4) * 10, 0, 10) // 6.5 eco → 10, 10.5 eco → 0
```

The expression yields 8.75 at an economy of 6.5, not 10. The completion document states a third, different formula again. One of the three must be made authoritative.

4.7 Academy matcher cannot rank a variant against a rival — New

Proven by test. Normalised Levenshtein has no notion of which token carries identity:

```
similarity('Sharma Cricket Academy', 'Sharma Cricket Acad.') = 0.8636 ← true variant
similarity('Sharma Cricket Academy', 'Verma Cricket Academy') = 0.8636 ← different academy
```

Identical scores. The reconciliation queue cannot order them. This is mitigated today because `prisma/seed.ts` only *suggests* at ≥ 0.55 and a human confirms — which is the conservative design the Pivot Document asked for. It becomes a data-integrity bug the moment an auto-confirm threshold is introduced. A token-weighted or Jaro-Winkler comparison would separate them.

4.8 W8 matching does not run at runtime — New

`bestSimilarity` is called only from `prisma/seed.ts`. No ingest path computes academy candidates, so the reconciliation queue is populated only by seeding.

4.9 Seven `package.json` scripts pointed at deleted files — Fixed in this work

`db:init`, `make-admin`, `e2e`, `audit:py`, `sweep:injection`, `check:api-contracts`, `smoke:e2e` all referenced `scripts/*` files archived in the restructure. They have been removed and replaced with the test scripts in §10.

4.10 Lower severity

- OTP hashes are unsalted SHA-256. A six-digit code is brute-forceable in milliseconds if the table leaks; HMAC with a server secret would fix it. Attempt limiting (5) and a 10-minute TTL are correctly implemented and tested.
 - `/api/tracking` returned a 500 on a cold start, then 200 on retry — Neon autosuspend, not a code defect, but worth a connection warm-up in production.
-

5. Environment status

Nothing is missing to run the application. The database is live and fully provisioned: 23 `athlasx` tables matching all 23 Prisma models, 41 legacy `public` tables untouched, with seed data present.

Three environment issues, none blocking runtime:

Issue	Impact	Fix
DATABASE_URL lives only in <code>.env.local</code>	Prisma CLI cannot see it, so <code>migrate</code> , <code>db push</code> , <code>db seed</code> , <code>studio</code> all fail validation — the app itself connects fine	add a root <code>.env</code> , or prefix with <code>dotenv -e .env.local</code> --
<code>.env.local.example</code> is stale	Documents the <i>archived</i> app (Aadhaar HMAC, NextAuth, Supabase) and omits <code>DATABASE_DIRECT_URL</code> , which the current schema requires	rewrite against the current schema
<code>SMS_GATEWAY_API_KEY</code> set but unused	Why <code>dev0tp</code> is returned instead of <code>sent</code> (\$4.3)	wire the gateway, drop <code>dev0tp</code>

The test harness works around the first issue with its own `.env.local` loader (`tests/helpers/load-env.ts`).

6. The test suite

The project had no test files, no framework and no `test` script. What now exists:

Stack. Vitest for unit/integration/security, Playwright (Chromium) for E2E. Both chosen for TypeScript-native execution against a Next.js App Router codebase.

Database isolation. Integration tests never touch live data. Because every Prisma model is pinned to the `athlasx` schema via `@@schema`, a connection-string change cannot redirect writes. `scripts/setup-test-db.mjs` therefore derives a parallel schema pinned to `athlasx_test`, generates a separate Prisma Client for it, and pushes the tables. Suites hoist `vi.mock('@/lib/db')` so routes under test resolve to the test client.

Isolation was verified before any test wrote a row:

athlasx	23 tables	3 rows in player_profiles	(live, untouched)
athlasx_test	23 tables	0 rows	(test, empty)
public	41 tables		(legacy, untouched)

`assertIsTestSchema()` runs in `beforeAll` and refuses to proceed if the harness is not pointed at `athlasx_test`.

Suite layout.

Directory	Purpose	Expectation
tests/unit/	Pure functions — score engine, OTP, name matching	must stay green
tests/integration/	Real route handlers against real Postgres	must stay green
tests/security/	Findings 4.1–4.4 as assertions	red until fixed
tests/known-defects/	Findings 4.5–4.7 as assertions	red until fixed
tests/e2e/	Playwright, all nine workflow pages	15 green, 2 red

The red suites are the deliberate part. Rather than describing the security findings in prose alone, each is written as a test asserting the behaviour the Pivot Document requires. They fail today; when a finding is remediated, its test turns green. That is the signal the finding is closed.

7. Results

UNIT + INTEGRATION	86 passed	(5 files)
SECURITY	10 failed	(intentional)
KNOWN DEFECTS	5 failed	(intentional)
E2E	15 passed, 2 failed	(intentional)
TOTAL	118 tests – 101 pass, 17 intentional failures	

What the green tests prove. The blind-grading boundary genuinely holds at the route level: convergence returns 403 before unlock, `/mine` returns only the caller's own grades and leaks neither the peer's selector id nor their grade value, unlock is chair-only and single-use, and grading closes once convergence opens. The claim flow correctly gates minors behind a guardian phone, sends the OTP to the guardian rather than the child, hashes it, limits attempts to five, expires it, and consumes it against replay. The score engine's not-out handling, TQI weighting, renormalisation and role weighting all behave as specified.

What the red tests prove. Every finding in §4.1–4.7, executably. Sample failure output:

```
X candidate-pool returned player PII with no credentials: expected 200 to be 401
X a grade was recorded on behalf of the chair by an unauthenticated caller
X convergence was unlocked by an unauthenticated caller supplying the chair id
X claim/start returned the OTP; anyone can claim any profile: expected '143175' to be undefined
X a player who withdrew consent is still returned by candidate-pool
X true variant scored 0.8636, a DIFFERENT academy scored 0.8636
```

One test initially passed for the wrong reason — the consent check on `/api/tracking` passed only because the seeded player had no `TrendAlert` and so never appeared at all. It was strengthened with a precondition assertion and now fails correctly. Worth noting because it is exactly how a test suite gives false comfort.

8. Coverage and what is not covered

```
Statements  43.54%  (216/496)
Branches    39.41%  (147/373)
Functions   35.84%  (38/106)
Lines       43.09%  (178/413)

src/lib      83.44%  ← score engine, OTP, name matching
```

The business logic is well covered. The gap is API routes: `dashboard`, `ingest`, `my-record`, `tracking`, `trial-cycles`, `coach`, `academy-matching` and `selection` have integration tests only indirectly (via the security suite) and are at or near 0% line coverage.

Deliberately not covered, and why:

- **Write paths on live data.** E2E runs against the real `athlasx` schema because the app has no auth to log into and pages read live data. Those tests are read-only by design; no E2E test submits a form that writes.
 - **React component rendering.** No component-level tests. E2E covers rendering at the page level, which is the higher-value check for a UI that is mostly presentational.
 - **The ingest pipeline.** There is nothing to test — no parsers, OCR or sync exist yet (\$4.8).
-

9. Remediation plan

Ordered by severity, then dependency.

Priority 1 — Security, before any pilot

1. **Add authentication.** Every route needs a session, and identity must come from that session rather than the request body. This single change closes §4.1 and §4.2 together and makes blind grading real rather than nominal.
2. **Remove** `dev0tp` **from the** `claim/start` **response** and wire the SMS gateway. Until then, no real player data should be loaded.
3. **Enforce consent on read paths.** Add `consent_status: { not: 'withdrawn' }` to the five queries in §4.4. Legal exposure, not just correctness.

Exit criterion: `npm run test:security` goes green — all 10 tests.

Priority 2 — Correctness

4. Add `source` provenance to coach ratings and reject unattributed values (§4.5).
5. Reconcile the bowling formula across code, comment and completion document (§4.6).
6. Replace the academy matcher with a token-weighted comparison (§4.7), and call it from the ingest path rather than only from the seed (§4.8).

Exit criterion: `npm run test:known-defects` goes green — all 5 tests.

Priority 3 — Hygiene

7. Create a root `.env` so the Prisma CLI works; rewrite `.env.local.example` against the current schema.
 8. Replace unsalted SHA-256 OTP hashing with HMAC.
 9. Correct `Pivot_Changes_ATHLASX.docx`: remove the coach-source claim, fix the bowling formula, and drop the "Not Yet Done" entries for files that do not exist in the repository.
 10. Raise API-route coverage above 70%.
-

10. How to run everything

```
npm install                # postinstall now runs prisma generate

npm run test:setup-db      # provision the athlasx_test schema (once)

npm test                  # everything – expect 17 intentional failures
npm run test:unit          # 52 tests, must be green
npm run test:integration   # 34 tests, must be green
npm run test:security      # 10 tests, red until Priority 1 is done
npm run test:coverage      # coverage summary

npm run build && npm run test:e2e  # 17 Playwright tests

npm run test:teardown-db   # drop the athlasx_test schema
```

A note on the red suites. `npm test` exits non-zero by design, because 17 tests assert behaviour the code does not yet have. Do not make them pass by weakening the assertions. Wire them into CI as two gates instead — a green gate on `test:unit` and `test:integration`, and a tracking signal on `test:security` and `test:known-defects` that flips to green as each finding is closed.

Audited at `main` @ `30ca63c`. Test suite added in the working tree, uncommitted.